

SECAUDIT 055 - Release packages shipped dev directories (tests/, wip/, smack-central/) into ~28 production installs

SECURITY AUDIT / PUBLIC REMEDIATION RECORD

Date	2026-09-04
Severity	HIGH overall, with one CRITICAL-conditional (fleet signing-key exposure) that must be verified on a live box, not assumed. No confirmed live RCE on a normally-packaged spoke; the crown-jewel tooling fails closed.
Scope	The release/clean-install packaging paths and every dev-only directory they leaked into the live docroot of ~28 fleet installs: tests/, wip/, smack-central/, and core/tests/. Plus the SMACKBACK integrity-monitoring gap that let it go unflagged.
Method	Three independent adversarial reviewers (smack-central surface / tests+wip surface / SMACKBACK gap), each grounded in file:line, synthesized here. Per the 050 rule: never a single self-audit. No exploit code.
Reporter	Sean (found it live via SFTP: "every single site I have checked"; "smackback should have been going off like a three-alarm fire") + Claude (3 reviewers + synthesis).
Status	Open (downgraded). F1 CLOSED 2026-09-04 - sc-config.php verified ABSENT on CT102 (sean-sites, bulk fleet) and CT106 (hub + challenge sites) via live find; no fleet-key exposure, no rotation. CT103/CT105 spot-check still owed if they host installs. Remaining: prevention fix (packager excludes) + containment (delete + SMACKBACK re-baseline). No confirmed RCE.

1. Summary

The release packagers shipped developer-only directories into production docroots fleet-wide. Three dirs, three mechanisms:

- tests/ (the CMS regression suite) and wip/ (work-in-progress skin/JS scratch) ship **actively** - neither is on either packager's exclude list. Confirmed by today's file dates on live boxes.
- smack-central/ (the vendor-side release/admin tooling) is **excluded now**, so it no longer re-ships; the copies on spokes are **stale** (dated ~2026-08-09), left from before the exclusion - and nothing removed them because the hub-push update path deliberately never deletes files.
- core/tests/ also ships (core/ is not excluded).

SMACKBACK - the file-integrity monitor that should have screamed - stayed silent by design: its baseline is a **disk scan** taken after each update, so the junk was folded into the trusted baseline (or, for wip/, excluded from monitoring entirely). See §4.

The overall risk is **information disclosure / hygiene failure with real teeth**, not confirmed remote code execution - *conditional on one fact the repo can't answer*: whether the untracked smack-central/sc-config.php (which holds the fleet Ed25519 release signing key) rode along into the shipped copies. That must be checked on a live box.

2. Root cause

Two packaging paths, both missing the same excludes:

- **Fleet-update packager** - smack-central/sc-release.php \$always_exclude (~line 467) lists docs/, secaudits/, migrations/, smack-central/, tools/... but **not** tests/ **or** wip/. (Fixed this session - tests/ and wip/ added.)

- **Clean-install packager** - tools/_build/build-install-package.php:75 \$exclude_dirs also omits tests and wip. (NOT yet fixed.)
- core/tests/ ships because core/ is never excluded (only specific sub-paths are).

Compounding: the hub-push update path (core/multisite-api.php:1729-1734) **deliberately never deletes files** (secaudit 029 - a hub-driven fleet-wide rm is itself a deletion primitive). So stale junk (like smack-central/ from before its exclusion) never leaves once landed. The auto-cleanup that exists (updater_remove_known_orphans, UPDATER_DEPRECATED_DIRS) runs **only** in the interactive local updater (smack-update.php), never on the fleet path - which is why wip/ (on the deprecated-dirs list since 0.7.426) is still everywhere.

3. Findings (ranked by reach to compromise)

F1 - CRITICAL-conditional -> CLOSED (verified absent 2026-09-04, CT102+CT106): fleet Ed25519 signing key at rest on public docroots

If any shipped smack-central/ copy contains sc-config.php, then every spoke holds - in plaintext, in a web-reachable directory - SMACK_RELEASE_PRIVKEY (the Ed25519 key that signs update packages AND VAX SQL payloads the whole fleet auto-trusts via core/release-pubkey.php), plus SNAPSMACK_GITHUB_TOKEN, FORUM_MOD_KEY, and hub DB creds (smack-central/sc-config.sample.php:32-33, 46, 54-55; consumed at sc-release.php:785, sc-vax.php:36). Anyone who reads that key can sign a malicious update/VAX that all 28 spokes + the hub accept and execute -> **fleet-wide RCE**.

- **Likelihood the file is present:** LOW by repo evidence - sc-config.php is gitignored (smack-central/.gitignore:1), so git archive/clean-checkout packages exclude it, and smack-central/ is on the official exclude list. **But the incident shipped these dirs via an abnormal path, so absence cannot be assumed.**
- **Action:** pull one spoke's smack-central/sc-config.php over SFTP and look. **If present -> treat the fleet release key as COMPROMISED and rotate** (rotation flow exists at sc-release.php:906-959). If absent -> F1 drops to N/A.

F2 - HIGH: sc-setup.php - unauthenticated bootstrap installer live on every spoke

The one smack-central/ endpoint that runs with **no config and no session** (no sc-auth/sc-config include), and it's directly reachable (§3a). Unauthenticated, an attacker can: force repeated ~220 MB GitHub-zip downloads + overwrite smack-central/ before any DB connect (sc-setup.php:220-240) = DoS + dir overwrite; MySQL-protocol **SSRF / internal port probe** with an error oracle (sc-setup.php:256-263); and - **if the spoke allows outbound MySQL or the attacker knows local DB creds** - bootstrap an attacker-owned SC admin (sc-setup.php:318-322, 371), log in, and push GitHub content into the spoke's web root via sc-update.php:294-309. It is designed to self-delete (sc-setup.php:382) and never should have persisted. **Held below CRITICAL:** planted content is GitHub-sourced (not arbitrary attacker code) and the takeover leg needs outbound MySQL/known creds.

F3 - HIGH: wip/ is a permanent SMACKBACK blind spot AND web-served

core/smackback.php:474 **excludes wip/ from monitoring**. A .php webshell dropped as wip/anything.php is never hashed, never appears in the unexpected diff, never trips a breach on any path - and there is no .htaccess deny, so it would execute. Today the tracked wip/ holds only HTML/JS/MD (inert - §F5), but the *directory* is the cleanest dormant-webshell home in the tree. **Note:** the tracked repo has **no .php under wip/**; if a live box shows .php in wip/, that is untracked, out-of-band scratch and a separate concern to investigate.

F4 - HIGH (aggregate): tests/ is an unauthenticated security-design recon map

All 35 tests/*-regression.php (plus core/tests/*.php) are directly requestable and **execute** (§3a). They take no attacker input, open no DB, write nothing to the docroot, change no state - but a meaningful subset echoes its full assertion list on every hit (provision-shared-key-regression.php:19, smackcast-relay-regression.php, fleet-relay-join-regression.php, curator-directory-regression.php), disclosing validation regexes, endpoint semantics, which controls enforce step-up auth, the fleet Bearer-key format (`^[a-f0-9]{64}$`), and export table/column allow/deny lists (tyswy-export-regression.php:59, 150, 162-166). Any single script is MEDIUM; across 28 identical public sites the aggregate is **HIGH** recon. tyswy-export-regression.php:45, 49, 53 also `eval()`s slices of production source - MEDIUM hygiene hazard, not exploitable (fixed trusted input).

F5 - LOW: wip/jive-turkey/ payload is inert

7 HTML prototypes + ss-engine-jive-turkey.js / ss-engine-jive-border.js + a status MD. Per JIVE-TURKEY-STATUS.md the engines are **not registered** in core/manifest-inventory.php; grep confirms no shipped.php references wip/. No innerHTML/location/eval XSS sink found. Discloses in-progress skin design only.

F6 - MEDIUM (the reassuring finding): smack-central/ crown-jewel tooling FAILS CLOSED on a stock spoke

sc-release.php, sc-backup.php, sc-schema.php, sc-vax.php, sc-update.php, sc-network-api.php, sc-enemy-api.php, etc. all begin with `require_once .../sc-config.php` (directly or via sc-auth.php:16). With sc-config.php absent (the likely case), that's a **fatal -> nothing runs**. Even with config, actions gate on a hub-DB-backed `$_SESSION['sc_admin_id']` (sc-auth.php:40, sc-login.php:104-108, no static backdoor) that cannot be established on a stock spoke (sc_db() throws against a non-existent hub DB). So the release-signing / DB-dump / schema-DDL / VAX-signing capabilities are inert as shipped - their safety rests entirely on the config-fatal and the DB-backed login. Conditional exception: sc-network-api.php / sc-enemy-api.php become live if a spoke is co-hosted so localhost+hub creds hit the real hub DBs (fleet false-alarm / push-subscriber injection / api-key mint - network-integrity, not host RCE).

F7 - MEDIUM: no web-serve deny for the dev paths; sensitive-file block misses the sc- prefix

.htaccess is generated from core/htaccess-template and has **no** /tests/, /wip/, **or** /smack-central/ **deny**. The FilesMatch block (:88) matches bare db|auth|constants|login.php only - sc-db.php/sc-auth.php/sc-config.php **slip past** (the sc- prefix defeats the anchored regex). The PHP-execution guard exists only in img_uploads/media_assets/assets/img, not these dirs. So all shipped.php under them executes directly.

4. Why SMACKBACK stayed silent (the "what broke")

Nothing crashed - the design has a blind spot. Every baseline path (install.php:1758, smack-update.php:1152/1417, core/multisite-api.php:1752) uses `smackback_init_from_disk()`, a **raw disk scan**, not the signed manifest. So:

- tests/ and smack-central/ (monitored, because their exclusion guard sc-config.php is absent) were **hashed into the trusted baseline as origin='disk'** - SMACKBACK actively vouches for their current bytes.
- wip/ is **excluded from monitoring** (F3) - invisible entirely.
- On every update the spoke **re-baselines from disk then auto-resolves any breach** (multisite-api.php:1752-1756), so anything on disk at update time is blessed and any standing alarm is cleared.

Consequence: SMACKBACK would still catch an attacker dropping a file *between* updates (UNEXPECTED) - but not junk that arrives *inside* the signed release and gets baselined in. That is exactly the silence Sean observed.

5. Remediation

Prevention (code - folds into the pending build):

1. Add tests/ and wip/ to smack-central/sc-release.php \$always_exclude. **[DONE this session]**
2. Add tests and wip to tools/_build/build-install-package.php:75 \$exclude_dirs. **[TODO]**
3. Exclude core/tests/ from both packagers. **[TODO]**
4. Add smack-central, tests (and confirm wip) to UPDATER_DEPRECATED_DIRS (core/updater.php:277) so the *local* updater removes them. **[TODO]** - note this does NOT reach the fleet path by design (see below).
5. Add a /tests/, /wip/, /smack-central/ deny + sc-* sensitive-file coverage to core/htaccess-template. **[TODO]**
6. Packager hardening: treat "a known dev dir present in the release tree" as a build-time FAIL, so this can never ride in a signed package again. **[TODO]**

Containment (fleet - the safe order; raw deletion alone locks out every admin): Because tests/ and smack-central/ hold *trusted* SMACKBACK manifest rows, deleting them raw makes SMACKBACK flag them MISSING -> breach-locks the admin on all 28 installs. The correct procedure per install:

1. **Verify F1 first:** read smack-central/sc-config.php on one spoke. If present -> **rotate the fleet signing key** before anything else.
2. Delete tests/, wip/, smack-central/, core/tests/ from the docroot. (wip/ needs no rebaseline - it was never monitored.)
3. Run smackback_init_from_disk() (via the in-admin "re-initialise baseline from disk" / repair, or a core update which auto-runs it) so the orphan-prune (smackback.php:986-998) drops the removed rows and smackback_mark_clean() clears the breach. **Only re-baseline a box confirmed clean** - re-baselining a compromised box would trust an intruder's files.

Open decision for Sean (do NOT flip silently): whether to wire the *scoped, signed-whitelist* updater_remove_known_orphans into the hub-push path so the fleet self-cleans. It reverses the explicit "no deletion on the hub path" boundary from secaudit 029 - arguably safe (it acts only on the spoke's own Ed25519-verified in-core list, not a hub-supplied one), but it is a security-boundary change and Sean's call.

6. Blast radius

~28 installs (Sean's count). All carry tests/ (actively shipped) and core/tests/; the older/most-updated carry stale smack-central/; wip/ where the release included it. F1 (the only unbounded item) is gated entirely on whether sc-config.php shipped - **verify before rating this incident.**

7. CLOSURE - 2026-09-05 (fixed in 0.7.641D, deployed and verified the next day)

F1 resolved before anything else, as required: the fleet signing key (sc-config.php) was verified ABSENT from live installs by direct filesystem inspection on both hosting containers - it is gitignored and the archive-based packager never included it. No key exposure, no rotation required.

Every layer shipped in 0.7.641D and rode the normal fleet update:

- **Packagers:** tests/, wip/ and core/tests/ joined the exclude lists in

both release builders, and the release build now HARD-FAILS - refusing to produce a package - if any dev path reaches the final zip.

- **SMACKBACK trust model (findings A+B):** the four dev-directory prefixes are

now *never-trust* paths - refused a baseline row by both init paths no matter how they arrive, previously-laundered rows pruned on the next scan, and *wip/* is no longer a monitoring blind spot. Files found under those prefixes surface in a dedicated red DEV DIRECTORIES bucket: loudly visible, and deliberately not a lockout while the class sat fleet-wide.

- **Self-cleaning updates:** the three directories joined the curated removal

whitelist, and the hub-push update path - the only path the fleet uses - now runs the same scoped, Ed25519-gated cleanup the manual updater always had. The "open decision for Sean" in §5 was decided by Sean on 2026-09-05: the scoped reversal of the 029 boundary was approved. What gets deleted remains fixed by signed core code, never a hub input. Cleanup runs BEFORE the integrity re-baseline, so the baseline captures the cleaned tree - the containment landmine in §5 was defused in code rather than by procedure.

- **Web layer:** the dev-directory subtrees return 404 via the self-healing

.htaccess rules, closing the unauthenticated *sc-setup.php* nuisance and the public regression-test map independently of disk cleanup.

Verified live 2026-09-05: the fleet update removed the directories from the installs automatically with ZERO admin lockouts (the exact failure mode §5 warned raw deletion would cause); the operator confirmed spot-checks and an external sweep of every fleet site found none offline. A 26-assert regression (*tests/secaudit-055-dev-dirs-regression.php*) pins every layer.

Named residuals (tracked, not blocking closure): two secondary hosting containers still owe a for-completeness absence check if they host installs; promoting dev-directory *presence* from warning to breach is parked until wanted; and the full "baseline only ever from the signed manifest" re-architecture is CONTAINED - the never-trust list plus the existing unexpected-file alarm kill the class that actually bit, and a fresh install's very first baseline remains the one window where a novel resident file would still be blessed.